

SOC 2 — Trust Services Criteria (Common Criteria 6.x excerpt)

> Source: AICPA Trust Services Criteria, public summary (<https://www.aicpa-cima.com/topic/audit-assurance/trust-services-criteria>). Used here as a public-domain compliance excerpt for Polaris demo input.

CC6.1 — Logical Access — Security Software, Infrastructure, and Architectures

The entity implements logical access security software, infrastructure, and architectures over protected information assets to protect them from security events to meet the entity's objectives. The entity restricts logical access to information assets, including hardware, data (at-rest, during processing, or in transmission), software, administrative authorities, mobile devices, output, and offline system components by following defined logical access security measures. Such measures include identification and authentication of users, authorization of subjects to access protected information assets based on roles and responsibilities, and protection of credentials and authentication tokens.

CC6.2 — Access Provisioning and Removal

Prior to issuing system credentials and granting system access, the entity registers and authorizes new internal and external users whose access is administered by the entity. For those users whose access is administered by the entity, user system credentials are removed when user access is no longer authorized. The entity restricts access to and protects credentials issued to users from disclosure to unauthorized parties.

CC6.6 — Logical Access — Boundary Protection

The entity implements logical access security measures to protect against threats from sources outside its system boundaries. The entity restricts the transmission, movement, and removal of information to authorized internal and external users and processes, and protects it during transmission, movement, or removal. This includes preventing unauthorized exfiltration of protected information assets to external destinations.

CC6.7 — Restriction and Monitoring of Privileged Access

The entity restricts the use of privileged identifiers and access only to authorized individuals. Activities of users with privileged access are logged and monitored. Privileged access requests are reviewed and re-authorized periodically. The entity prevents privileged users from disabling, modifying, or circumventing logging and monitoring controls.

CC7.2 — System Monitoring and Anomaly Detection

The entity monitors system components and the operation of those components for anomalies that are indicative of malicious acts, natural disasters, and errors affecting the entity's ability to meet its objectives. Anomalies are analyzed to determine whether they represent security events.